

Using AI Responsibly Day to Day

WHY THIS MODULE MATTERS

Most people will never approve a model or sign a DPIA. They will, however, paste something into a chatbot this week. This module covers generative AI, agents and personal conduct — the governance that applies to everyone.

3.1 Generative AI Is a Different Risk Shape

Generative systems produce fluent, confident, plausible output regardless of whether they have any basis for it. That single property changes what governance has to guard against.

A conventional predictive model produces a score, and a score invites scepticism. A generative model produces prose, and prose invites belief. The output carries no signal about its own reliability: a fabricated citation is written with exactly the same confidence as a correct one. Everything else in this module follows from that.

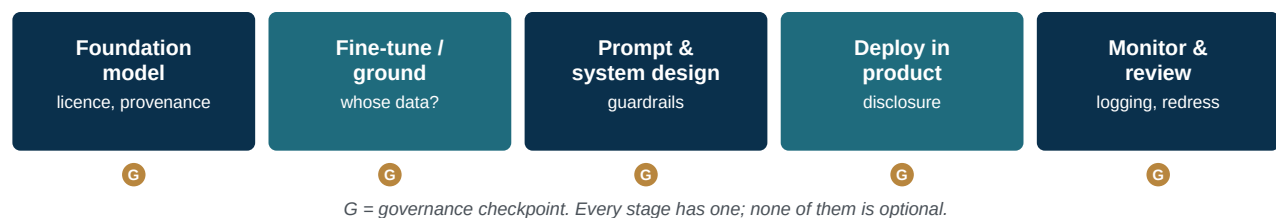


Figure 3.1 — The generative AI lifecycle, with a governance checkpoint at each stage.

3.2 What Goes In

Anything entered into a third-party AI tool has left your organisation. Depending on the terms of service and the plan, it may be retained, reviewed by humans, or used to train future models. This applies to personal data about customers or colleagues, to commercially confidential material, and to anything under a duty of confidence to a client.

CASE STUDY — SAMSUNG AND THE PASTED SOURCE CODE

In 2023, engineers at Samsung Semiconductor used ChatGPT to help with work tasks. In separate incidents within a few weeks they pasted in confidential source code to debug it, proprietary test sequences to optimise them, and a recording of an internal meeting to be summarised.

None of this was malicious and none of it was prohibited at the time — there was no policy covering it. The engineers were using an available tool to do their jobs faster, which is precisely what everyone hopes staff will do.

Samsung restricted generative AI on company devices and began developing an internal alternative. The governance lesson is about sequencing: the organisation adopted the tool through its staff before it decided what the rules were. Guidance issued in week one costs almost nothing; guidance issued after the fact costs a great deal and arrives too late.

3.3 What Comes Out

The organisation owns what its AI tools say to customers. This is now settled in practice, and the reasoning is not novel: a business is responsible for information presented on its own channels regardless of which internal component produced it.

CASE STUDY — AIR CANADA AND THE CHATBOT'S PROMISE

A passenger asked Air Canada's website chatbot about bereavement fares. The chatbot told him he could book at full price and claim a refund within ninety days. That policy did not exist; the chatbot had generated it.

When the airline refused the refund, the passenger went to the British Columbia Civil Resolution Tribunal. Air Canada argued the chatbot was a separate legal entity responsible for its own statements. The tribunal rejected this firmly, holding the airline responsible for all information on its website, and ordered it to pay.

The sum was small; the principle is not. There is no meaningful distinction, in liability terms, between a page on your website and a sentence your chatbot generates.

Three practical rules follow. Verify any factual claim, figure, citation or legal statement before it leaves the organisation. Disclose AI involvement where a reasonable person would want to know — customer-facing content, generated imagery of people, automated correspondence. And never let generated output be the final word on a decision about a person.

3.4 Agents Act, Which Raises the Stakes

An AI agent is permitted to take actions — send messages, update records, place orders, call other systems — rather than only produce suggestions. The governance difference is that an error becomes an event in the world rather than a proposal a human can decline.

Agents also introduce a distinctive vulnerability. Because they read content in order to act on it, instructions hidden inside that content can hijack them. A document, email or web page containing text addressed to the model rather than the reader can cause the agent to take actions its operator never intended. This is prompt injection, and it has no complete technical fix at present.

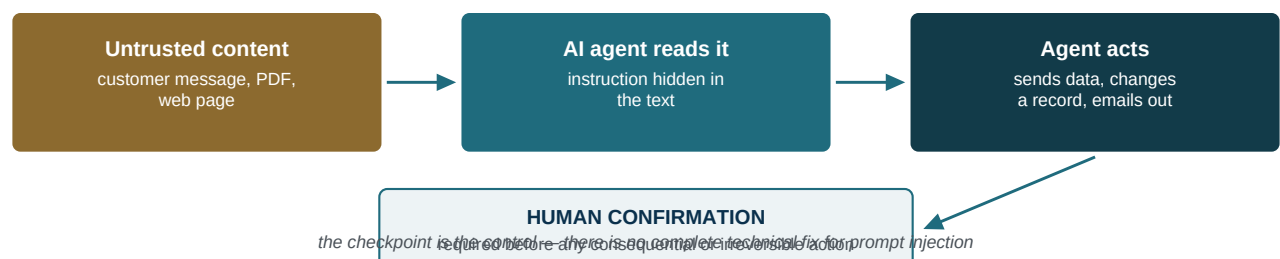


Figure 3.2 — How a prompt injection reaches an agent, and where a human checkpoint interrupts it.

The mitigation is architectural rather than clever: constrain what the agent is permitted to do, require human confirmation before consequential or irreversible actions, and log everything it does in a form a person can

review afterwards. An agent with narrow permissions and a confirmation step is manageable. An agent with broad permissions and none is an unmonitored employee.

3.5 Personal Conduct

Two habits matter more than any policy. The first is disclosure to colleagues: if AI materially produced work you are presenting as your own analysis, say so. The issue is not the tool; it is that colleagues make decisions based on assumptions about how carefully something was checked.

The second concerns what you post publicly. Anything identifying your employer, your clients, internal systems, unreleased work or colleagues who have not consented is capable of causing damage that no policy will undo afterwards. If a journalist or member of the public contacts you about your organisation's use of AI, the correct response is to be courteous, decline to comment personally, and pass it to whoever is designated to speak — regardless of how confident you are that you know the answer.

3.6 Keeping It Going

Governance decays without a cycle. The Plan-Do-Check-Act structure underlying ISO/IEC 42001 is a reasonable default: decide what you will do, do it, measure whether it worked, and change it on the basis of what you found.



Figure 3.3 — The Plan-Do-Check-Act cycle underlying ISO/IEC 42001.

TRY THIS — SCENARIO: THE MONDAY MORNING TEST

You manage a team of eight. On Monday you learn that: one analyst has been pasting client call transcripts into a public AI tool to summarise them; a second has published a report containing two statistics the tool generated and nobody checked; and the customer service assistant on your website has begun quoting a delivery guarantee that your operations team does not offer.

Rank these three in the order you would deal with them, and write one line justifying the order. Then decide, for each, whether the appropriate response is a rule, a control or a conversation — and note which of the three could still be happening in six months if you only issue a policy.

KEY TAKEAWAYS

- Generative output is fluent regardless of accuracy — fluency carries no signal about reliability, and a fabricated citation looks exactly like a real one.
- Anything entered into a third-party AI tool has left the organisation and may be retained or used for training.
- The organisation is liable for what its AI tools tell customers; there is no separation between a chatbot's statement and the website it sits on.
- Agents act rather than suggest, and are vulnerable to instructions hidden in the content they read — constrain permissions, confirm consequential actions, log everything.
- Disclose material AI involvement to colleagues, keep internal detail off public channels, and route media contact to the designated spokesperson.
- Governance needs a repeating cycle; Plan-Do-Check-Act is sufficient structure for most organisations.

FURTHER READING

- ISO/IEC 42001 — AI management systems standard
- NCSC — guidance on the security of AI systems and prompt injection, [ncsc.gov.uk](https://www.ncsc.gov.uk)
- *Moffatt v Air Canada*, British Columbia Civil Resolution Tribunal (2024)

CHECK-IN QUIZ

1. An employee uploads a recording of an internal strategy meeting to a public AI tool to get a summary. The most significant issue is that:

- A. The transcription may be inaccurate
- B. Meeting recordings require consent from all participants
- C. Confidential material has left the organisation and may be retained or used for training
- D. The summary cannot be relied upon for minutes

CHECK-IN QUIZ

2. A consultant includes three case citations produced by a generative tool in a client report without checking them. The governance failure is:

- A. Treating fluent output as verified fact when fluency carries no signal of accuracy
- B. Using AI without disclosing it to the client
- C. Breaching the tool's terms of service
- D. Failing to complete a DPIA

3. An AI agent is given broad access to internal systems with no confirmation step before it acts. Module 3 characterises this as:

- A. An acceptable trade-off for efficiency
- B. A breach of Article 22
- C. The equivalent of an unmonitored employee
- D. A configuration that eliminates prompt injection risk

4. Which post on a personal social media account is most likely to cause real damage?

- A. A photograph of an unreleased product on your desk
- B. A job-change announcement naming your new employer
- C. A general comment about AI regulation in the UK
- D. A link to your employer's published press release

5. Why does Module 3 recommend disclosing material AI involvement to colleagues?

- A. Because undisclosed AI use breaches UK GDPR
- B. Because AI output cannot be relied upon at all
- C. Because the organisation must log every use of AI
- D. Because colleagues make decisions based on assumptions about how carefully work was checked